

- i. Personnel at alternate sites, including arrangements for those permanently located at the alternate facility.
  - j. Scope and frequency of testing.
  - k. Resumption of a normalized state for business processes.
2. If management outsources the BCP's development, verify that management maintains oversight and ownership of the BCP.
  - a. Determine whether management verified the third-party service provider's qualifications and expertise.
  - b. Verify that entity management worked with the third-party service provider to design executable and viable strategies.
  - c. Verify that the plan reflects the entity's current products, business processes, and third-party service providers.
  - d. Determine whether roles and responsibilities reflect the entity's current organizational structure.
3. Determine whether the BCP includes event management procedures that detail reasonably foreseeable event types, and those procedures include threshold metrics and response methods.
  - a. Verify that procedures explain how to report an event to management and the situations that warrant notification.
  - b. Determine whether management (either an individual or team) has implemented procedures to communicate with both internal and external stakeholders.
  - c. Verify that event management processes include event response procedures that are appropriate to the event.
4. Assess management's protocols for operations continuity and system recovery. Verify that procedures are clear, concise, accessible, and can be implemented in an emergency. Verify the BCP includes procedures for the following:
  - a. Manual steps for critical functions, as applicable.
  - b. Alternate identity verification methods.
  - c. Fraud identification and suspicious activity reporting.
  - d. Other procedures as applicable. Examples may include:
    - Addressing customer service requests during downtime.
    - Tracking daily transactions.
    - Reconciling general ledger accounts.
    - Documenting operational tasks.
    - Posting entries after system recovery.
    - Maintaining backup records to provide customer account information (account numbers, customer names, addresses, account status, and account balances).
5. Verify that the BCP lists alternatives for core operations, facilities, infrastructure systems, suppliers, utilities, interdependent business partners, and key personnel.

- a. Verify that the BCP includes site relocation for short-, medium-, and long-term scenarios.
  - b. Determine whether management considers scalability.
  - c. Verify that recovery alternatives can accommodate the services and processing capabilities affecting critical operations, including:
    - Core processing.
    - Check processing and imaging.
    - Commercial cash management.
    - Mailing, faxing, and printing.
    - Customer identification.
    - Data center activities.
6. Verify that the BCP includes procedures for coordination with the first responders and local and state government agencies, when appropriate.
  7. Verify that the BCP includes procedures to establish an alternate physical location(s) where personnel and customers can go to conduct business, if appropriate.
  8. Determine whether the BCP addresses alternate arrangements in the event payment systems fail (e.g., ATMs, funds transfers, electronic banking, remote deposit capture, mobile capabilities).
    - a. Determine whether the BCP addresses processes for retrieving and transmitting transactions when payment systems are disrupted (e.g., manual procedures for calling in or faxing wire or automated clearing house requests to correspondent banks; mitigating strategies for web-based systems; or third-party software used to perform transactions).
    - b. Determine whether management verifies that redundant electronic payment systems and equipment (e.g., tokens and routers) are included at recovery sites for activation and that documentation is maintained for timely posting of entries when systems are recovered.
    - c. Determine whether instant issue cards are utilized and card company security procedures are implemented to limit potential fraud.
  9. Verify that the BCP addresses the entity's cash management requirements. Procedures may include:
    - a. Pre-established cash delivery arrangements.
    - b. Plans for increases in branch traffic when ATMs are unavailable.
    - c. Plans for the entity's operational cash needs.
    - d. Temporary purchase authority guidelines.
    - e. Expense reimbursement options for personnel.
    - f. Higher-limit credit cards or separate checking accounts with designated individuals who can sign checks in emergency situations.
  10. Determine whether management established an incident response process. As part of incident management planning, determine whether management does the following:

- a. Aligns incident response procedures with other related processes (e.g., cybersecurity, network operations, and physical security).
  - b. Considers incident response procedures during the development of the business continuity strategy.
  - c. Leverages routine processes (e.g., vulnerability management and network monitoring) to anticipate potential incidents, including cyber incidents.
11. Verify that management developed a coordinated disaster recovery strategy for data centers, networks, servers, storage, service monitoring, user support, and related software. Verify that procedures address the following:
  - a. Security controls and protocols, including physical and logical.
  - b. Procedures for restoring backlogged activity or lost transactions to identify how transaction records will be brought current within expected recovery time frames.
  - c. Instructions to access the repository of critical information when the primary facility is unavailable.
12. Verify whether management designates key personnel from applicable departments to act during a crisis or emergency situation. Key personnel may include:
  - a. Senior management for leadership.
  - b. Facilities management for safety and physical security.
  - c. Human resources for personnel issues and travel.
  - d. Media relations for managing communications.
  - e. Finance and accounting for funds disbursement and financial decisions, including unanticipated expenses.
  - f. Legal and compliance for legal and regulatory concerns.
  - g. IT, including information security, and operations for specific tactical responses.
13. Determine whether management established a crisis or emergency management process. Verify whether the BCP addresses the following:
  - a. Coordination with regulatory agencies, local and state officials, law enforcement, and first responders.
  - b. Disruptions not confined to a single event, facility, or geographic area.
  - c. Simultaneous disruptions of telecommunications and electronic messaging, including between the entity and third-party service providers.
  - d. Crisis or emergency management communication protocols, including the designation of a spokesperson(s) to communicate with the news media, as appropriate.

**Objective 9: Determine whether the BCM program includes training and awareness to educate stakeholders about the entity’s continuity objectives and BCM goals. (VI, “[Training](#)”)**

1. Verify that the training program aligns with the entity’s BCM strategy. Determine whether management does the following:
  - a. Inventories the current skillsets for BCM and identifies and addresses any training gaps.

- b. Establishes goals and objectives for supporting the BCM program as part of the entity's performance management process.
  - c. Implements a training program to educate stakeholders about the BCM goals and objectives. Elements may include:
    - Exercises.
    - Current risks.
    - Future risks.
    - Recent failures.
    - New programs/technologies.
    - Organizational changes.
    - Previous (exercise) lessons learned.
2. Assess whether management tailors training to the target audience, based on the audience's needs. The target audience could include:
  - a. Board members.
  - b. Senior management.
  - c. Business process owners.
  - d. Frontline personnel.
  - e. Contract personnel, as applicable.
3. Validate that management incorporates significant business continuity concepts, interdependencies, disruption impacts, and operations resilience into the training program.
4. Verify that the BCM training program, including board training, is updated as significant changes occur.

**Objective 10: Determine whether the exercise and testing program is sufficient to allow management to assess the entity's ability to meet its continuity objectives. (VII, "[Exercises and Tests](#)")**

1. Determine whether management implemented a comprehensive exercise and testing program, objectives, and plans to validate the entity's ability to restore critical business functions.
2. Verify that the program is appropriate for the entity's risk profile. Assess whether the entity's consolidated exercise and test schedule is reflective of exercise and test objectives and the overall exercise and test universe.
3. Determine whether management covers all of the functions in the exercise and test universe according to its established timeframes (e.g., all processes are covered annually or every three years).
4. Determine whether management has designated personnel with the authority to control the exercise or test and confirm exercise and test milestones are met.

5. Verify that business line management retains ownership for testing its specific business processes and coordinates with personnel involved in the enterprise-wide BCM process and support areas.
6. Verify that exercises and tests occur at appropriate intervals, or when significant changes affect the entity's operating environment.
7. Verify that management developed a process that is sufficiently robust to confirm the effectiveness of the entity's business continuity program. Therefore, the exercise program should incorporate the following:
  - a. A policy that includes strategies and expectations for exercise and test planning.
  - b. Roles and responsibilities for implementation.
  - c. Sufficient personnel to perform the exercise or test, provide oversight, and document the results.
  - d. Precautions to safeguard production data, such as performing a backup before performing a test in a test environment, or testing during non-peak hours.
  - e. Provisions for emergency stops and concluding exercises and tests.
  - f. Verification of continuity and resilience process assumptions and the ability to process a sufficient volume of work during adverse operating conditions.
  - g. Activities commensurate with the importance of the business process.
  - h. Entity's processes commensurate with their significance to critical financial markets.
  - i. Comparison of exercise and test results against the BCP to identify gaps between the exercise or test process and recovery guidelines, with revisions incorporated where appropriate.
  - j. Independent review of business continuity program and exercises and tests (internal and external).
8. Determine whether the exercise and test policy is appropriate and includes the following:
  - a. Key roles and responsibilities.
  - b. Minimum frequency, scope, and reporting.
  - c. Documentation expectations.
  - d. Processes for correcting deficiencies identified during exercises or tests.
  - e. Communication and connectivity between the entity and third-party service providers.
  - f. Participation with critical third-party service providers to confirm that entity personnel understand integration with all related recovery processes.
9. Determine whether the exercise and test strategies allow management to demonstrate the entity's ability to support connectivity, functionality, volume, and capacity using alternate facilities. Strategies may include the following:
  - a. Expectations for individual business lines and use of exercise and testing methodologies and scenarios.
  - b. Internal and external dependencies, including activities outsourced to domestic and foreign-based third-party service providers.

- c. Multi-year plan(s) to execute the specific depth and breadth of exercises and tests, which use different methodologies and scenarios over time.
  - d. Expectations for testing internal and external recovery dependencies.
  - e. Assumptions, methodologies, and exercises used to develop the test strategies.
  - f. Transaction processing and functional testing to assess the recoverability of infrastructure, capacity, and data integrity.
10. Verify that exercise and test objectives include resilience, system monitoring, and the recovery of business processes and critical system components.
11. Verify that exercises and associated tests accomplish the following objectives:
  - a. Build confidence that resilience and recovery strategies meet business requirements.
  - b. Demonstrate that critical services can be recovered within agreed upon recovery objectives (RTOs, RPOs, and MTDs) and customer SLAs.
  - c. Establish that critical services can be restored in the event of an incident at the recovery location.
  - d. Familiarize staff with recovery processes.
  - e. Verify that personnel are adequately trained and knowledgeable of recovery plans and procedures.
  - f. Confirm that exercise and test plans remain compatible with the BCP and the entity's infrastructure.
  - g. Identify any gaps between business continuity procedures and objectives.
12. Determine whether management established exercise and test plans, commensurate with the nature, scale, and complexity of the recovery objectives that address the objectives and expectations of the exercise or test and outline the scenario and any assumptions or constraints that may exist. Verify whether exercise and test plans include the following:
  - a. Identification of roles and responsibilities for participants, support personnel, and observers.
  - b. Metrics to assess whether objectives are met.
  - c. A consolidated exercise and test schedule that encompasses all objectives.
  - d. Specific descriptions of objectives and methods.
  - e. Roles and responsibilities for all test participants, including support personnel.
  - f. Identification of decision makers and succession plans.
  - g. Exercise and test locations to be utilized.
  - h. Escalation procedures and the ability to adjust for simulated scenarios.
  - i. Contact information.
13. Determine whether management developed reasonably foreseeable threat scenarios that simulate disruptions in business functions and the ability to meet both business requirements and customer expectations. Management should:
  - a. Identify and document assumptions used in developing each scenario.

- b. Develop scenarios that include threats that could affect third-party service providers, including communication processes with applicable stakeholders.
  - c. Develop exercises that demonstrate not only the ability to failover to an alternate site but also validate recovery objectives.
  - d. Create scenarios that include only the data and systems that would be available for recovery.
- 14. Verify that exercise and test scripts document the procedures for executing the exercise or test, which may include:
  - a. Applications, business processes, systems, or facilities reviewed.
  - b. Sequential steps for employees or external parties to perform.
  - c. Procedures to guide manual work-around processes.
  - d. A detailed schedule for completion.
  - e. Methods for participants to record results, quantifiable metrics, and any issues.
- 15. Assess whether exercise and test methods are commensurate with the size and complexity of the entity and the criticality of the function to the entity. Verify that exercises and tests are designed to do following:
  - a. Validate personnel knowledge and skills, including backup responsibilities.
  - b. Operate and perform duties (e.g., daily, quarterly, annually) from an alternate site.
  - c. Process transactions and assess system functionality.
  - d. Test the viability of both full and incremental backups.
  - e. Test network connectivity and interdependencies, including those with critical third-party service providers.
- 16. If management performs full-scale exercises, verify whether the exercise includes the following, where appropriate:
  - a. Engaging personnel from all business units to participate and interact with internal and external management response teams.
  - b. Validating that the crisis/emergency management process is operating as designed.
  - c. Verifying personnel knowledge and skills.
  - d. Validating management response and decision-making capability.
  - e. Demonstrating coordination among participants and decision makers.
  - f. Validating communication protocols.
  - g. Conducting activities at alternate locations or facilities.
  - h. Processing data using backup media or alternative methods.
  - i. Completing actual transactional volumes or an illustrative subset.
  - j. Performing recovery exercises over a sufficient length of time to allow issues to unfold as they would in a crisis.
- 17. If management performs limited-scale exercises, verify whether the exercise includes the following, where appropriate:

- a. Implementing a plan appropriate to the scenario.
  - b. Verifying personnel knowledge and skills.
  - c. Validating management response and decision-making capability.
  - d. Executing on-the-scene coordination and decision-making roles.
  - e. Verifying whether participants can connect to alternate system(s).
  - f. Conducting activities at alternate locations or facilities.
  - g. Testing communication and remote access capability (e.g., switching to alternate equipment or telecommuting).
18. If management performs tabletop exercises, determine whether targeted plans and procedures are reasonable, personnel understand their responsibilities, and different departmental or business unit plans are compatible with each other. (By themselves, tabletop exercises are likely insufficient to validate recovery capabilities because they are limited to a discussion-based analysis of policies and procedures.) Tabletop exercises may include the following:
  - a. Engaging operational and support personnel who are responsible for implementing the BCP.
  - b. Practicing and validating specific functional response capabilities.
  - c. Demonstrating knowledge and skills, as well as team interaction and decision-making capabilities.
  - d. Role playing with simulated responses, evaluating critical steps, recognizing difficulties, and resolving problems.
  - e. Clarifying critical plan elements, as well as problems noted during exercises.
  - f. Creating action plans to correct issues.
19. Verify that management clearly defines the characteristics of a successful test, which may include the following:
  - a. Validating RPOs, RTOs, and MTDs.
  - b. Demonstrating recoverability at peak volumes.
  - c. Confirming that systems can support critical business processes (e.g., transfer to alternate sites, increased workloads, manual workarounds, and communication).
  - d. Integrating technologies that support critical business activities, including data replication, recovery, and off-site storage.
  - e. Testing backup data to assess integrity and availability.
  - f. Certifying facility controls (e.g., environmental, backup power, and physical security).
  - g. Verifying workspace restoration (e.g., network connectivity and communications).
  - h. Ensuring that personnel are familiar with and are able to execute their responsibilities.
20. Determine whether the right to perform testing or participate in exercises and tests with third parties is described in the contract governing the entity's relationship with the third-party service provider.
21. Determine whether exercises and tests with third-party service providers are included in the entity's enterprise exercise and test program based on the risk prioritization of the third-party



service provider and the criticality of the services provided to the entity. Assess the following:

- a. The process to rank third-party service providers based on criticality, risk, and testing scope.
  - b. Coordinated exercises and tests that reasonably validate the abilities of both the entity and the third-party service provider to recover, restore, resume, and maintain operations after disruptions consistent with business and contractual requirements.
  - c. Evidence that exercises and tests of critical service providers include reasonably foreseeable significant disruptive events.
  - d. Documentation of the scope, execution, and results of exercises and tests in which the entity is unable to directly participate.
22. Determine whether the entity participates in its critical third-party service providers' exercise and test program(s) at reasonable intervals. Assess the execution of the exercises and tests and whether they included the following:
- a. End-to-end and, when appropriate, full-scale exercises.
  - b. Transaction processing and functional testing.
  - c. Network connectivity and interdependencies to include those with critical fourth parties.
  - d. Bidirectional operations between the entity's and its third-party service provider's primary and alternate locations and systems.
  - e. Supply chain considerations.
23. Determine whether testing scenarios with critical third-party service providers consider the following:
- a. An outage or disruption of the service provider.
  - b. An outage or disruption at the entity.
  - c. Incident response plans.
  - d. Crisis management plans.
  - e. Communication processes with third-party service providers and other stakeholders.
  - f. Cyber events.
  - g. Returning to normal operations.
24. Determine whether the tests validate the core or significant firm's backup arrangements to confirm the following:
- a. Backup sites are able to support typical payment and settlement volumes for an extended period.
  - b. Backup sites are fully independent of the critical infrastructure components that support the primary sites.
  - c. Trained employees are located at the backup sites at the time of disruption.
  - d. Backup site employees are independent of the staff located at the primary site at the time of disruption.

- e. Backup site employees are able to recover clearing and settlement of open transactions within the time frames addressed in the BCM processes and applicable industry standards.
25. Determine whether the exercise and test assumptions are appropriate for core and significant firms and consider the following:
- a. Primary data centers and operations facilities that are completely inoperable without notice.
  - b. Whether personnel at primary sites, who are located at both data centers and operations facilities, are unavailable for an extended period.
  - c. Whether other organizations are also affected, causing effects that have the potential to cascade from one organization across to the entire financial services sector.
  - d. Infrastructure (e.g., power, telecommunications, transportation) that is disrupted.
  - e. Whether data recovery or reconstruction to restart payment and settlement functions can be completed within the time frames defined by the BCM process and applicable industry standards.
  - f. Whether continuity arrangements continue to operate until all pending transactions are closed.
26. Determine whether the core firm's testing strategy includes plans to test the ability of significant firms that clear or settle transactions to recover critical clearing and settlement activities from geographically dispersed backup sites within a reasonable time frame.
27. Determine whether the significant firm has an external exercise and test strategy that addresses key interdependencies, such as exercises and tests with third-party market providers and key customers, and determine the following:
- a. Whether external exercise and test strategies include the significant firm's backup sites to the core firm's backup sites.
  - b. Whether the significant firm participates in industry (e.g., U.S. Department of the Treasury's Hamilton Series and FS-ISAC's CAPS exercises) or cross-market tests sponsored by core firms, markets, or trade associations. Tests should incorporate verifying the connectivity from alternate sites and include transaction, settlement, and payment processes, to the extent practical.
28. Determine whether the exercise and test program is sufficient to demonstrate the entity's ability to meet its continuity objectives and whether the results demonstrate the readiness of personnel to achieve the entity's recovery and resumption objectives. Determine whether management accomplishes the following:
- a. Coordinate the execution of its exercise and test program to fully exercise its business continuity planning process.
  - b. Analyze and compare results against stated objectives.
  - c. Raise issues with appropriate personnel and assign responsibility for resolution.